

ResolvX

Data Loss Prevention Policy

Topic-Specific Policy - Data Exfiltration Prevention & Coverage Roadmap

POL-019 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-019
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual, or upon DLP tooling change
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A8.12 · NIST CSF 2.0 PR.DS-05 · SOC 2 CC6.7

1. Purpose

This Data Loss Prevention (DLP) Policy establishes how ResolvX prevents Restricted and Confidential data from leaving its control through unauthorised channels and defines the coverage ResolvX is actively expanding toward as its data footprint grows.

DLP protects the same data POL-004 classifies as Restricted or Confidential, at the specific point where it would otherwise leave ResolvX's environment such as an outbound email, a shared file, an API response, or an object storage bucket made public. This policy documents current coverage honestly, including where it doesn't yet reach, so that gap is a formally accepted and tracked decision rather than an undocumented assumption.

2. Scope

This policy applies to all channels through which Restricted or Confidential data (per POL-004) could leave ResolvX's control:

- Corporate email and file sharing (Google Workspace).
- Cloud object storage (Amazon S3).
- API responses and integrations with third parties.
- Endpoint data egress (USB, personal cloud storage, unmanaged file transfer).

3. Current Coverage

Google Workspace's native DLP rules are configured across corporate email and Drive, covering the primary channel ResolvX personnel use to handle documents day to day:

- Outbound email is scanned for patterns consistent with Restricted-tier data (e.g., financial account number formats, government ID patterns) and blocked or flagged for review before sending externally.
- Drive sharing rules restrict external sharing of files containing detected sensitive patterns without explicit override.
- IT Admin administers these rules through the Workspace Admin Console.

4. Coverage Gaps & Residual Risk Acceptance

ResolvX does not currently operate dedicated DLP tooling covering API traffic, S3 object storage, or endpoint-level data egress (e.g., USB, unmanaged personal cloud uploads). This gap was assessed as acceptable at the programme's inception given ResolvX's size at the time; it is formally reassessed here rather than left as an implicit assumption.

Following the risk acceptance authority structure in POL-014 §5, this gap is logged as a Moderate risk, formally accepted by the CISO pending the roadmap in §5, and reassessed at each quarterly risk review thus not treated as permanently closed by this policy.

5. DLP Coverage Roadmap

Stage	Description	Target
Stage 1 - Workspace (current)	Email and Drive DLP rules, as described in §3	In place
Stage 2 - S3 data discovery	Deploy AWS Macie or equivalent to discover and classify sensitive data in S3, and alert on public or overly permissive bucket exposure	Target: Q3 2026
Stage 3 - SaaS visibility (CASB)	Evaluate a Cloud Access Security Broker for broader visibility into SaaS data movement beyond Workspace	Following Stage 2
Stage 4 - Endpoint & API egress	Extend coverage to endpoint data egress and API response monitoring for Restricted-tier data patterns	Following Stage 3

GRC Lead and Head of Cloud Ops jointly own this roadmap's execution, reflecting their combined responsibility for privacy risk tracking and cloud infrastructure respectively.

6. DLP Alert Handling

A DLP rule firing is a signal to investigate, not an automatic incident. IT Admin triages Workspace DLP alerts as part of routine administration; where a triaged alert indicates likely unauthorised exfiltration rather than an inadvertent internal misdirection, it is reported immediately under POL-015 §4 and handled through the standard incident process from that point forward.

7. Roles & Responsibilities

7.1 GRC Lead

- Owns this policy and the residual risk acceptance in §4.
- Tracks roadmap progress (§5) and reports it as part of the quarterly risk review under POL-014.

7.2 Head of Cloud Ops

- Leads Stage 2 (S3 data discovery) execution and any subsequent cloud-focused stage.

7.3 IT Admin

- Administers Workspace DLP rules and triages resulting alerts (§6).

7.4 CISO

- Holds formal acceptance of the residual risk in §4 and approves any change to the roadmap's priority or timeline.

8. Compliance and Enforcement

Deliberate circumvention of a DLP control such as disabling a rule without authorisation or knowingly using an uncovered channel specifically to move Restricted-tier data externally is addressed under POL-002's disciplinary process. Failure to progress the roadmap in §5 against its target dates is logged as a Corrective Action Plan item.

9. Document Control

Policy ID	POL-019
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual, or upon DLP tooling change
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A8.12 · NIST CSF 2.0 PR.DS-05 · SOC 2 TSC CC6.7
Related Documents	POL-004 (Data Classification Policy), POL-014 (Risk Management Policy), POL-015 (Incident Management Policy)

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		